

THREAT ADVISORY



**VULNERABILITY
REPORT**

**Zero-day Vulnerability in the WordPress
BackupBuddy Plugin**

Date of Publication

September 13, 2022

Admiralty Code

A1

TA Number

TA2022200

Summary

A zero-day vulnerability in the BackupBuddy WordPress plugin is being actively exploited. There are an estimated 140,000 active installations of the plugin, and the arbitrary file download/read vulnerability is identified under CVE-2022-31474.

CVE Table

CVE	NAME	PATCH
CVE-2022-31474	Arbitrary File Download/Read	

Potential MITRE ATT&CK TTPs

TA0001 Initial Access	T1190 Exploit Public-Facing Application	T1189 Drive-by Compromise	TA0002 Execution
T1203 Exploitation for Client Execution	TA0040 Impact	T1565 Data Manipulation	T1565.001 Stored Data Manipulation

Technical Details

The BackupBuddy WordPress plugin is intended to make backup management simple for WordPress site operators. 'Local Directory Copy' which is one of the plugin's capabilities allows you to save backups locally. These locally stored files were handled in an inadequate manner, allowing unauthenticated users to download any file.

Vulnerability Details

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-31474	BackupBuddy: 8.5.8.0 - 8.7.4.1	cpe:2.3:a:ithemes:back upbuddy:- :*:*:*:*:wordpress:*:*	CWE-285

Indicator of Compromise (IOC)

TYPE	VALUE
IPV4	195[.]178.120.89 51[.]142.90.255 51[.]142.185.212 52[.]229.102.181 20[.]10.168.93 20[.]91.192.253 23[.]100.57.101 20[.]38.8.68 20[.]229.10.195 20[.]108.248.76

Patch Links

<https://ithemes.com/blog/wordpress-vulnerability-report-special-edition-september-6-2022-backupbuddy/>

References

<https://www.wordfence.com/blog/2022/09/psa-nearly-5-million-attacks-blocked-targeting-0-day-in-backupbuddy-plugin/>

What Next?

Book a free demo with **HivePro Uni5** to check your exposure to this advisory. HivePro Uni5 is a Continuous Threat Exposure Management Solution that proactively reduces an organization's attack surface before it gets exploited.



At Hive Pro we take a long hard look at your vulnerabilities so you can bolster your defenses and fine-tune your offensive cybersecurity tactics.

REPORT GENERATED ON

September 13, 2022 • 3:59 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com